

A Research on Data Secure Access Control Mechanism Based on Zero Trust and Attribute Encryption in Medical Cloud

Huang Nana

The Third Research Institute of The Ministry of Public Security
Shanghai, China

1058219406@qq.com, Huangnn@mctc.org.cn

Yang Yuanyuan

The Third Research Institute of The Ministry of Public Security
Shanghai, China

1058219406@qq.com, Huangnn@mctc.org.cn

Abstract—With the rapid development of cloud computing, a new health information exchange mode of personal health record (PHR) on cloud has become a hot topic. Many medical services are outsourced or provided by the third-party service provider, which is bound to lose direct control of the PHR files, while the cloud service provider may collude with other unauthorized users to disclose legitimate users' privacy in order to gain profits. At present, many scholars apply attribute encryption to cloud storage platform to ensure that PHR files are not transmitted in plaintext during the whole access process, but it cannot solve the semi-trust problem of cloud service providers and key distribution servers themselves. Therefore, in order to solve problem of data security and privacy protection of PHR data sharing scheme on semi-trusted servers, this paper introduces the security concept of "zero trust" to construct a data security access control framework based on zero trust and attribute encryption in the medical cloud. This framework can realize real-time monitoring and trust measurement of the behavior of the client and the server, and can dynamically adjust the access permissions of PHR user resources according to the measurement results. The security analysis results show that the proposed scheme can achieve more secure and reliable data access control in medical cloud.

Keywords—personal health record, zero trust, attribute encryption, access control, trust measurement

I. INTRODUCTION

With the emergence of cloud computing, BYOD (mobile office) and other new IT technologies, it is increasingly difficult to define the boundary of network security. Complex network access environment, a large number of network assets and ubiquitous security threats (DDOS, phishing attacks, APT, scanning, penetration, database collision, etc.) are constantly threatening enterprise security. In recent years, with the rapid development and application of mobile Internet technology, more and more enterprise staff tend to mobile work. Users' network usage is highly dynamic. A user may have different roles at the same time, and the application services and resources accessed by different roles may be different or cross. From the business development level, more enterprise business began to the cloud, because the traditional network environment construction has already can't satisfy the business development needs, and establishing a cloud network architecture is the trend of the development of the enterprise

network. But this new working way also causes the change of the new system boundary, and the boundary becomes more complicated and blurred. Traditional protection schemes based on fixed boundaries have gradually become ineffective, and a new security model is needed to cope with the security threats posed by the enterprise on cloud. When the network boundary is not clearly defined, the managed network security policy becomes more and more limited. Then there is the hidden risk that the boundaries between assets are not well established.

The problem of implicit trust exists in the traditional network boundary environment. The traditional network security structure defaults that the internal network is more secure than the external network, and to some extent, the staff, devices, systems and applications on the internal network is "implicit trust". In the borderless network environment, the boundary between "Intranet" and "extranet" becomes increasingly blurred. And the same problem exists in the medical cloud. In the medical cloud, the third party server and client is credible by default in the access control scheme proposed previously. Aiming at this problem, this paper puts forward access control method based on zero trust and attribute encryption to guarantee the medical data not leaked, to ensure the diagnosis and treatment business process safe and controllable, and to assure the secure access of the medical data in the whole process. The contributions of this paper are as follows:

- First, the paper introduces the security concept of "zero trust" to construct a data security access control framework based on zero trust and attribute encryption in the medical cloud to realize real-time dynamic access control mechanism compared with the existing schemes;
- Second, it solves the problem that the third party and server are not completely trusted in the previous scheme to reduce the risk of cloud service providers and middleware servers being attacked, and realize secure data access in the whole process;
- Third, it can achieve fine-grained access control by real-time monitoring and dynamic adjustment of user behavior accessing to the PHR data.

II. RELATED WORK

Cloud computing is a new computing model based on virtualization, parallel and distributed computing. People can use the convenience brought by cloud computing to temporarily store some idle resources in the cloud to share computing resources [1]. The development momentum of cloud computing is immeasurable, and the user-centered medical cloud has great development potential. Combined with cloud computing, Internet of Things, multimedia and other new technologies, medical cloud achieves the sharing of medical information, aiming to improve the health of the masses of people, improve the medical system, and contribute to the overall improvement of medical level at home and abroad [2]. In the medical cloud system, each PHR data owner stores his medical records on a third-party cloud server [3]. We mainly focus on how to achieve efficient and secure sharing schemes to protect data privacy. The most common scheme is to encrypt files when uploading them. The traditional public key encryption scheme [4] is only suitable for encryption in a single user scenario, and will bring users a lot of computing burden. Recently, the commonly used encryption scheme is the attribute encryption ABE proposed by foreign countries, which is suitable for encryption in multi-user scenarios [5],[6]. In recent years, many domestic scholars began to focus on attribute encryption. Li et al. [7] proposed a data sharing scheme based on attribute encryption in medical cloud, in which different users are divided into different regions and corresponding encryption schemes are used. The scheme details that layered CP-ABE is used in the public domain and KP-ABE is used in the private domain, but their scheme is completely based on attribute encryption. Attribute encryption itself has many problems which can not be solved, such as attribute revocation, key management, dynamic policy update and so on. In order to solve the above problems, Fan et al. [8] proposed a more systematic, secure and efficient scheme, but this scheme assumes that the third party is a trusted institution and all communication between entities uses standard security protocols. In order to solve this problem, this paper introduces the concept of "zero trust" to construct a data security access control framework based on attribute encryption in medical cloud.

The concept of zero trust was proposed by KINDERVAG, an analyst at Forrester[9] in 2010. Zero trust recognizes the shortcomings of the traditional border security and believes that hosts should be regarded as Internet hosts no matter where they are located on the network. The network, whether it is the Internet or the internal network, must be seen as a dangerous network full of threats[10]. One of the characteristics of the zero-trust concept is the default distrust, always authentication and minimum authorization, which can greatly reduce the risk of cloud service providers and middleware servers being attacked.

III. DETAILS OF OUR SCHEME

A. The Design of the Scheme

Medical cloud users are characterized by a large number of complex identities and a large number of attributes, making it difficult to conduct unified management. In this one-to-many communication scenario, ciphertext strategy based attribute

encryption scheme (CP-ABE) is suitable for data sharing in this region [8]. In the traditional (CP-ABE) scheme, the data owner sets a certain access policy for the encrypted file and encrypts the file with the access policy. Only when the attributes of the user meet the access structure can the file be accessed, otherwise, the user has no access to the file. If there is only a single authorized institution which is responsible for attribute revocation or key distribution and management, the system bottlenecks can be easily caused. And the system need the single authorization center fully credible, so it is difficult to meet the security requirements of distributed application. There are multiple authorized institutions in the actual application scenario, such as hospitals, insurance institutions, research institutions, etc. Each authority is responsible for key distribution and management for its own region, and the set of attributes owned by a legitimate PHR user is distributed by different non-overlapping authority.

In order to reduce the computing burden of PHR users, the outsourcing decryption ABE scheme is adopted. The cloud server does not directly send ciphertext to PHR users. The specific process is as follows: Firstly, the PHR data owner uplows the encrypted PHR file to the cloud server, and PHR users send PHR file requests to the cloud server after being authorized by the authorization authority. Secondly, the cloud server sends the file to the proxy server for partial decryption, and then sends part of the ciphertext to the corresponding PHR user. All key distribution is performed by the authorization center, including the transform key for partial decryption by the proxy server and the private key for decryption by the PHR user.

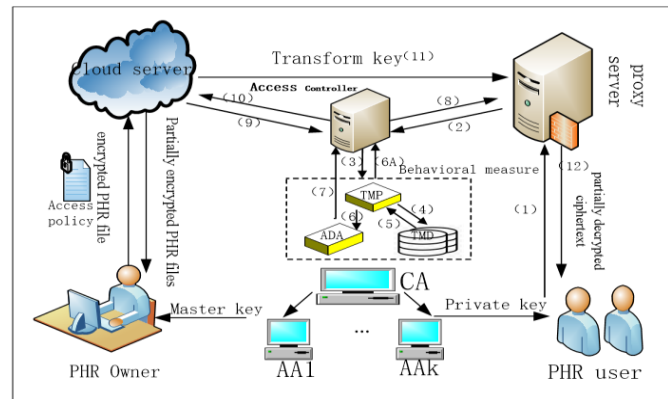


Fig. 1. System framework.

In the previous attribute encryption schemes, cloud service providers are regarded as semi-trusted institutions. On the one hand, they would carry out users' orders according to regulations; on the other hand, they might carry out behaviors beyond regulations for high profits, such as disclosing users' privacy. Root CA is trusted institution, while each regional CA may be trying to get user information outside of his management areas in order to profit, and the cloud is partially trusted, they may also conspire to leak user privacy. Besides, users can get the PHR files outside of his own permission by collusion attack. So all the above will inevitably lead to data privacy leakage. This paper draws on the concept of zero-trust, adopts the stance of "never trust and always verify", conducts periodic and continuous monitoring on the behavior of the

client and the server in the network, constructs an access control model based on behavior trust measurement, and solves the untrusted problem existing in the previous attribute encryption schemes. The medical cloud architecture based on this model is shown in the Fig. 1, which consists of PHR user, PHR data owner, root CA, regional AA, behavior controller, cloud service provider, proxy server and behavior measurement module. The behavior measurement module which includes trust measure proxy, access decision agent, trust measurement database and access controller can measure the trust level of untrusted terminals. When the trust level falls to untrusted, PHR users are blocked from accessing PHR files by behavior access controller.

B. The Description of Attribute Encryption and Decryption Module

1) The key management

The root CA is responsible for managing regional AA, such as hospitals, insurance institutions, and some research institutions. Each regional AA generates and manages the keys of the users in the region, which simplifies the key distribution and management.

2) The encryption and uploading of files

The symmetric key is used to encrypt the PHR file first, because it is convenient to generate the symmetric key. And then the symmetric key is encrypted with the attribute encryption method of the scheme. The two encrypted files will be uploaded to the cloud server. If the PHR files are encrypted by the attribute encryption method directly, it will require complex computation to encrypt the very large PHR files. For the symmetric keys are small, the encryption is less complicated.

3) The key generation

The authorization center firstly determines whether the PHR user's identity is legitimate. If yes, the authentication center enters the set of attributes owned by the PHR user and generates the corresponding conversion key and private key and sends them to the cloud server and PHR user respectively.

4) The File decryption

The PHR user firstly sends a file access request to the CSP. After the CSP receives the access request, it starts to search PHR files and sends the found PHR files to the proxy server. The proxy server partially decrypts the PHR files with the corresponding user's. If the attribute set of PHR users meets the access structure, it runs the Transform algorithm to obtain the partially decrypted PHR files. Then partially decrypted PHR files are sent to PHR users. PHR users decrypt the partially decrypted PHR files by the private key distributed by the authorized institution. If PHR user have the collection of attributes fit for the access structure set by the PHR data owner, he can decrypt correctly to get symmetric key, and then use the symmetric key to decrypt the PHR file to access it.

C. Description of the Behavior Measurement Module

The specific model of the zero-trust access control framework is shown in Fig 2.

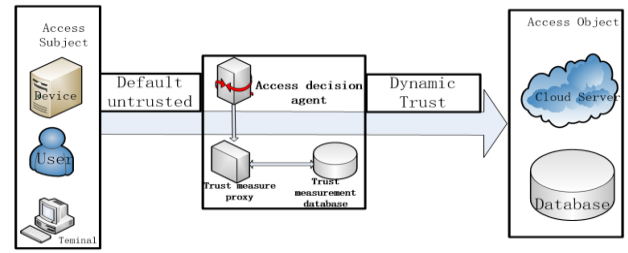


Fig. 2. The zero-trust access control framework.

1) *Trust measure proxy (TMP)*: The device can measure user behavior trust which is deployed with behavior measurement middleware to identify network attacks with long latency and high concealment, such as APT attacks and so on. The trust level of behavior is measured periodically by real-time measurement in the trust measurement database.

2) *Access decision agent based on behavior trust (ADA)*: The device which is deployed access decision-making middleware can deliver the access policy according to the user's trust level. It can design the corresponding decision function according to the requirements of different security intensity and different trust levels. After the decision is made, the policy packet is sent to the access controller for delivery.

3) *Trust measurement database (TMD)*: Store the historical behavior measurement data of the measured object. When it logs on the network, the behavior measurement agent will evaluate the initial trust level of the object based on the historical behavior measurement data in the database.

4) *Access controller*: The access controller can dynamically adjust access permissions of the user and server by sending flow tables, which follows the principle of continuous monitoring and verification in zero-trust networks.

D. Access Control Process Based on Zero Trust

As is shown in Fig. 1, the specific access control process based on zero trust is as follows:

- (1) The PHR user sends file access requests to the proxy server;
- (2) The proxy server sends a trust measure request to the access controller;
- (3) The access controller forwards the measurement request to the trusted measurement agent;
- (4) The trust measurement agent requests the behavior data of the applied user to the trust measurement database;
- (5) The trust measurement database queries the data behavior of the corresponding user and return to the trust measurement agent;
- (6) The trust measurement proxy sends the measurement results to both the access controller and the access decision agent based on behavior trust;
- (7) The access decision agent returns the decision result to the access controller;
- (8) The access controller returns the final trust measure to the proxy server;
- (9) The cloud server submits trust measure request to the access controller;
- (10) The access controller return the result;

- (11) If the trust measure result of the user and the cloud server match the requirements, the TK key is returned;
- (12) The proxy server returns the decrypted PHR file to the PHR user.

IV. SECURITY ANALYSIS

This paper will elaborate the security analysis from the following three aspects, which can be seen from Table I.

TABLE I. COMPARISON OF SECURITY

Scheme	CA collusion attack	Server collusion attack	User collusion attack	Type of CA
Hur[13]	no	default trusted	no	Multi-authorized
Ruj[11]	Against single AA collusion	default trusted	no	Multi-authorized
Lew[12]	no	default trusted	no	Single-authorized
Fan[8]	Against single AA collusion	default trusted	no	Multi-authorized
Our scheme	Against N-1 AA collusion	Against server collusion attack	Against abnormal User	Multi-authorized

Firstly, in this paper, the outsourcing multi-agency authorization based on attribute encryption scheme is adopted because of the uncertainty of user identity and the large scale of users. At present, the authorization center is unique in most of the existing attribute encryption schemes, and in the whole attribute encryption scheme, all key generation and distribution are in charge of the authorization center, so once the information leakage problem occurs in the authorization center, the user's privacy security becomes a serious hidden danger. In order to protect user privacy and improve system security, we introduce the concept of multi-authorization center into the scheme, and classify massive attributes in the way of multi-agency authorization. The private key of each PHR user is a collection distributed by different non-overlapping authorization institutions. These institutions can generate corresponding private keys according to the attributes of PHR users and send them to PHR users. The set of attributes owned by PHR users is the set of attributes distributed by various institutions. In this way, privacy disclosure and single point of failure caused by a single authorization institution which manage all users' private keys can be avoided. Besides, the problem of untrust regional AA can be solved by trust measurement in our scheme.

Secondly, compared with the previous attribute encryption schemes, cloud service providers were regarded as semi-trusted institutions. On the one hand, they would carry out users' orders according to regulations; on the other hand, they might execute behaviors beyond regulations for high profits, such as disclosing users' privacy. Root CA is trusted institution, while each regional CA may be trying to get user information outside of his management areas in order to profit, and the cloud is partially trusted, they may also conspire to leak user privacy. So all the above will inevitably lead to data privacy leakage. In this scheme, zero-trust security concept is introduced. Real-time monitoring of cloud server is carried out through behavior measurement module. If abnormal behavior measurement

results are returned, the communication will be blocked immediately to ensure PHR data security.

Thirdly, the analysis of suspicious behavior of users is always lacked in the previously proposed medical cloud scheme. With the globalization of network connectivity, network hackers launch malicious attacks by imitating normal user behavior and changing attack technique. If the client is attacked to get the corresponding private key, the PHR file can be decrypted, thus resulting in privacy disclosure. In this scheme, the concept of zero trust is introduced, and the trust level of untrusted users is measured according to the behavior measurement module. When the trust level falls to untrusted, PHR users are blocked from accessing PHR files, so as to solve the data leakage caused by abnormal user behavior.

V. CONCLUSION

This paper adopts the secure concept of zero trust and combines the attribute encryption to achieve more safer and more fine-grained access control mechanism in the medical cloud. In the scheme, the attribute encryption ensures data security in the transmission process. Besides, according to the results of the measurement by the real-time monitoring and behavior trust metrics of the client and server, the access permission of PHR users can be adjusted dynamically. In addition, it solves the problem that the third party and server are not completely trusted in the previous scheme to reduce the risk of cloud service providers and middleware servers being attacked, and realize secure data access in the whole process. The security analysis results show that the proposed scheme can achieve more secure and reliable data access control in medical cloud.

ACKNOWLEDGMENT

This work was supported by Public Security Industry-Standard Project(2021BZ226) and Technical Standard Project of Shanghai Science and Technology Innovation Action Plan (20DZ2205100) (C21702).

REFERENCES

- [1] http://baike.baidu.com/link?url=DbvCDAbXNqXgijVJmIeqkQeGuHEwUsB049L_3_svggBjCrcowrUcEHsp1Ryvs4zYtF0Hv1bUsMWw_IPc5JIK, 2015.
- [2] Löhr H, Sadeghi A R, Winandy M. Securing the e-health cloud[C]//Proceedings of the 1st ACM International Health Informatics Symposium. ACM, 2010: 220-229.
- [3] Li M, Yu S, Cao N, et al. Authorized Private Keyword Search over Encrypted Data in Cloud Computing[C]// International Conference on Distributed Computing Systems. 2011:383 - 392.
- [4] Benaloh J, Chase M, Horvitz E, et al. Patient controlled encryption: ensuring privacy of electronic medical records[C]//Proceedings of the 2009 ACM workshop on Cloud computing security. ACM, 2009: 103-114.
- [5] A. Boldyreva, V. Goyal, and V. Kumar, "Identity-Based Encryption with Efficient Revocation," Proc. 15th ACM Conf. Computer and Comm. Security (CCS), pp. 417-426, 2008.
- [6] L. Ibraimi, M. Petkovic, S. Nikova, P. Hartel, and W. Jonker, "Ciphertext-Policy Attribute-Based Threshold Decryption with Flexible Delegation and Revocation of User Attributes," 2009.
- [7] Li M, Yu S, Zheng Y, et al. Scalable and secure sharing of personal health records in cloud computing using attribute-based encryption[J]. Parallel and Distributed Systems, IEEE Transactions on, 2013, 24(1): 131-143.

- [8] Fan K, Nana H, Wang X, et al. Secure and Efficient Personal Health Record Scheme Using Attribute-Based Encryption [J]. *Networking and Applications*, 2017(2):1-12.
- [9] KINDERVAG John. Forrester Build Security into Your Network's DNA:The Zero Trust Network Architecture[EB/OL]. https://www.virtualstarmedia.com/downloads/Forrester_zero_trust_DNA.pdf,2010-11-10.
- [10] NIST. Zero Trust Architecture .[EB/OL]. <https://csrc.nist.gov/publications/detail/sp/800-207/archive,2019-9-23>.
- [11] S. Ruj, A. Nayak, and I. Stojmenovic, "DACC: Distributed Access Control in Clouds," *Proc. IEEE 10th Int'l Conf. Trust, Security and Privacy in Computing and Comm. (TrustCom)*, 2011.
- [12] A. Lewko and B. Waters, "Decentralizing Attribute-Based Encryption," *EUROCRYPT: Proc. 30th Ann. Int'l Conf. Theory and Applications of Cryptographic Techniques: Advances in Cryptology*, pp. 568-588, 2011.
- [13] Hur J, Shin Y, Yoon H. Decentralized group key management for dynamic networks using proxy cryptography[C]//*Proceedings of the 3rd ACM workshop on QoS and security for wireless and mobile networks*. ACM, 2007: 123-129.